Security & Privacy Disclosure, Final Report

ImmoScout24 Austria Android (at.is24.android)

A pre-consent advertising SDK initializes ahead of every other component, including Firebase, on a platform where users enter net household income for a mortgage calculator, two early replies disputed severity and redirected to a bug-bounty program without disputing a single manifest-level fact, and after that exchange six further follow-ups over 68 days drew no reply at all through and past the embargo date

PUBLIC DISCLOSURE, 17 OCTOBER 2026 — EMBARGO REACHED 28 SEPTEMBER 2026, TWO EARLY REPLIES RECEIVED AND DISPUTED, THEN SILENCE, THREE QUESTIONS NEVER ANSWERED

Target	Scout24 SE (Berlin) — operator of ImmoScout24 Austria; security correspondence handled by Scout24 SE's Security Engineering team (security@scout24.com)
Package	at.is24.android
Platform Audited	Android, static analysis of the production APK
Initial Disclosure (R1)	2026-06-30, to datenschutz@immobilienscout24.de (bounced on every attempt) and security@immobilienscout24.de, CC presse@scout24.com, Austrian Datenschutzbehoerde and EDPS, BCC German BfDI
Disclosure / Embargo Date	2026-09-28
Report Published	2026-10-17
Overall Severity	HIGH
Findings	5 (3 High, 2 Medium, 0 Critical)
Correspondence	9 messages sent by RFI-IRFOS over 74 days (2026-06-30 to 2026-09-12), 2 replies received (both on 2026-07-06, from Scout24 SE's Security Engineering team), disputing severity and redirecting to a bug-bounty program without disputing the underlying manifest-level facts, followed by 68 days of silence across 6 further follow-ups through and past the embargo date, none of the three technical questions ever answered
Authorities Notified	Austrian Datenschutzbehoerde (dsb@dsb.gv.at) · European Data Protection Supervisor (EDPS, edps@edps.europa.eu) · German BfDI (poststelle@bfdi.bund.de, BCC)

security@rfi-irfos.com • rfi-irfos.com
ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 4

2 Subject & Operator Context 5

3 Engagement Summary 5

4 Findings 6

4.1 C1: Two hardcoded Google API keys (Firebase, Crash Reporting, Maps Geo API) with no certificate-fingerprint binding . . . 6

4.2 H1: Advertising mediation SDK (AppLovin MAX) initializes at the highest priority value in the app, ahead of Firebase, on a platform collecting net household income . . . 7

4.3 H2: MortgageCalculatorComposeActivity exported without permission protection . . . 7

4.4 H3: Topics API, AD_ID, and attribution permissions layered on real-estate search behaviour constituting financial-intent data . . . 8

4.5 H4: Usercentrics CMP present (857 classes) but AppLovin, Google Mobile Ads, and Firebase all initialize pre-consent . . . 8

5 Impact Analysis 9

6 The Complete Chain: Nine Messages, 109 Days, Two Early Replies That Disputed Severity Not Fact, Then Silence 9

7 Data Protection – Article by Article 10

8 Regulatory & Legal Landscape 10

9 Indicators of Compromise 11

10 Disclosure Timeline & Outcome 11

11 Residual Risk & Recommendations 12

Executive Summary

ImmoScout24 Austria is Scout24 SE's Android app for Austria's largest real-estate search platform, published under at.is24.android. A static analysis of the production APK found two hardcoded Google API keys (serving Firebase, Crash Reporting, and the Maps Geo API) with no certificate-fingerprint binding, an advertising mediation SDK (AppLovin MAX, 1,535 classes) initializing at the highest priority value in the entire app, ahead of Firebase and Google Mobile Ads, on a platform whose own mortgage calculator and solvency-check flow collect net household income, available equity, and credit need before any consent dialog can appear, an exported mortgage-calculator activity startable by any other app on the device, and advertising-identifier permissions layered on top of that same financial-intent search behaviour.

RFI-IRFOS disclosed these findings on 30 June 2026 to datenschutz@immobilienscout24.de and security@immobilienscout24.de, with Scout24's press office, the Austrian Datenschutzbehoerde, and the EDPS in CC and the German BfDI in BCC per standing practice, stating an embargo date of 28 September 2026. The datenschutz@immobilienscout24.de address bounced on every single attempt to use it throughout the entire correspondence.

On 6 July 2026, Scout24 SE's Security Engineering team (Lani Lambert) replied twice within roughly two hours. The first reply assessed the findings as medium-severity at most, characterized them as unconfirmed static observations requiring runtime validation, and redirected RFI-IRFOS to Scout24's bug-bounty program. After RFI-IRFOS countered point by point, identifying each finding as a deterministic manifest-level or resource-level fact the Android operating system itself reads and enforces (not a runtime claim requiring dynamic proof), Scout24's second reply reiterated the same medium-at-most assessment, repeated the bug-bounty redirect, and did not dispute any of the three named facts. Neither reply answered any of the three specific yes/no questions RFI-IRFOS had asked.

Six further follow-ups were sent after that exchange (23 July, 12 August, 14 August, 24 August, 3 September, 12 September 2026), spanning 68 days, restating the findings and the three questions. None drew any reply. The embargo of 28 September 2026 passed with the questions still unanswered. This report publishes 19 days after that embargo, with the full record intact: two early replies that disputed severity but not fact, then complete silence through and past the stated deadline.

ID	Severity	Title
C1	HIGH	Two hardcoded Google API keys (Firebase, Crash Reporting, Maps Geo API) with no certificate-fingerprint binding
H1	HIGH	Advertising mediation SDK (AppLovin MAX) initializes at the highest priority value in the app, ahead of Firebase, on a platform collecting net household income
H2	HIGH	MortgageCalculatorComposeActivity exported without permission protection
H3	MEDIUM	Topics API, AD_ID, and attribution permissions layered on real-estate search behaviour constituting financial-intent data

ID	Severity	Title
H4	MEDIUM	Usercentrics CMP present (857 classes) but AppLovin, Google Mobile Ads, and Firebase all initialize pre-consent

Subject & Operator Context

ImmoScout24 Austria is operated by Scout24 SE, headquartered in Berlin (parent entity Scout24 AG, listed on the MDAX under ticker G24), Austria's largest online real-estate search platform. RFI-IRFOS's original disclosure was addressed to Scout24's Austrian data-protection mailbox and security mailbox; all substantive correspondence that followed was conducted with Scout24 SE's central Security Engineering team in Berlin, by Security Engineer Lani Lambert, who replied on behalf of Scout24 SE.

Engagement Summary

RFI-IRFOS sent the initial disclosure on 30 June 2026 to datenschutz@immobilienscout24.de and security@immobilienscout24.de, with Scout24's press office, the Austrian Datenschutzbehoerde, and the EDPS in CC and the German BfDI in BCC, stating an embargo date of 28 September 2026 and asking three specific yes/no questions about AppLovin's pre-consent initialization, the Art. 35 DPIA status, and whether the exported mortgage-calculator flag and pre-consent ad-init would be fixed before or after the Datenschutzbehoerde's first inquiry. The datenschutz@immobilienscout24.de address bounced immediately and on every subsequent attempt to use it.

On 6 July 2026, security@scout24.com replied twice. The first reply, from Security Engineer Lani Lambert, assessed the findings at a high level as medium-severity at most, framed them as static observations requiring runtime validation to establish any security impact, characterized the disclosure's tone as pressure-based outreach, and offered Scout24's bug-bounty program as the appropriate channel. RFI-IRFOS responded the same day, naming each finding (the hardcoded keys, AppLovin's initOrder value, and the exported activity's missing permission attribute) as a deterministic fact read directly from the shipped APK's manifest and resource files, not a runtime claim, and explained that RFI-IRFOS's own methodology reserves live Frida-based testing for signed, authorized engagements, never for an unsolicited disclosure against infrastructure it has no authorization to test. Scout24's second reply, roughly ninety minutes later, acknowledged that the underlying manifest and resource entries are indeed observable by static analysis, but maintained that this does not establish the severity, exploitability, or regulatory conclusions RFI-IRFOS drew from them, reiterated the medium-at-most assessment pending demonstrated impact, and again pointed to the bug-bounty program. Neither of Scout24's two replies disputed a single named fact, and neither answered any of the three yes/no questions.

Six further follow-ups were sent after that exchange (23 July, 12 August, 14 August, 24 August, 3 September, 12 September 2026), each restating the findings and the three questions. From 12 August onward, the address used was switched from the bouncing datenschutz@immobilienscout24.de to is24-datenschutz@scout24.com, alongside security@scout24.com, following the direct pattern of Scout24's own replies. None of these six messages, spanning 68 days after the 6 July exchange, drew any further reply of any kind.

Findings

C1: Two hardcoded Google API keys (Firebase, Crash Reporting, Maps Geo API) with no certificate-fingerprint binding

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:L/SC:N/SI:N/SA:N, 8.3 — RFI-IRFOS blast-radius escalation: two keys shared across three Google Cloud services (Firebase, Crashlytics, Maps Geo API), unrestricted and unbound to the production signing certificate, giving any third party who downloads the public APK a path to exhaust shared quota across all three services simultaneously for the entire Austrian user base

```
res/values/strings.xml -> google_api_key: [REDACTED IN PUBLIC REPORT -- disclosed
    privately to Scout24 in R1]
res/values/strings.xml -> google_crash_reporting_api_key: [REDACTED IN PUBLIC REPORT
    -- disclosed privately to Scout24 in R1]
res/values/strings.xml -> maps_api_key: [REDACTED IN PUBLIC REPORT -- disclosed
    privately to Scout24 in R1]
firebase_database_url: [REDACTED IN PUBLIC REPORT -- disclosed privately to Scout24 in
     R1]
Keys reused for: Firebase, Crashlytics, Maps/Geo API
Reachable by: any party decompiling the published APK
```

Impact: Two separate Google API keys (one shared by Firebase and Crash Reporting, a second for the Maps Geo API) are hardcoded, verbatim, in the production APK's res/values/strings.xml, alongside the Firebase Realtime Database URL the first key is wired to. Both values are withheld from this public report; full values were disclosed privately to Scout24 in the original R1 letter. Neither key is bound to the production signing certificate's fingerprint. RFI-IRFOS blast-radius escalation: raised from HIGH/7.5 to HIGH/8.3 because the exposure is not a single key tied to one service, as in comparable findings in RFI-IRFOS's other 2026 reports, but two keys spanning three distinct Google Cloud services, any one of which an unauthenticated third party can exhaust via unlimited API calls, with the realistic effect of disabling core app functionality (crash reporting, maps, Firebase-backed features) for Scout24's entire Austrian user base, not merely one feature.

H1: Advertising mediation SDK (AppLovin MAX) initializes at the highest priority value in the app, ahead of Firebase, on a platform collecting net household income

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:L/SI:L/SA:N, 7.1 — automatic, affects every install, no user action required to trigger

```
<provider android:name="com.applovin.sdk.AppLovinInitProvider" android:initOrder
    ="101"/>  <!-- highest in app -->
<provider android:name="com.google.firebase.provider.FirebaseInitProvider" android:
    initOrder="100"/>
<provider android:name="com.google.android.gms.ads.MobileAdsInitProvider" android:
    initOrder="100"/>
AppLovin smali classes: 1,535 (max mediation platform; AdColony also present)
Usercentrics CMP: 857 smali classes (full TCF 2.2 integration, not gating the above)
Financial-intent strings present: finquest_budget_income (net household income),
    more_preferences_solvency_check, expose_pluswall_benefit_3
```

Impact: AppLovin MAX (1,535 smali classes), an advertising mediation platform, is declared with android:initOrder=”101” in the manifest, the highest initOrder value in the entire app, ahead of Firebase (100) and Google Mobile Ads (100). This ContentProvider-enforced ordering is read and applied by the Android framework itself on every install, before the Usercentrics consent dialog (857 classes, full TCF 2.2 integration, confirming Scout24 is aware of the consent requirement) can be shown. The app's own mortgage calculator and solvency-check flow collect net household income, available equity, and credit need. Scout24's own 6 July replies did not dispute AppLovin's initOrder value or its ordering relative to Firebase and Usercentrics; they disputed only whether this constitutes a confirmed security or regulatory finding without further runtime validation.

H2: MortgageCalculatorComposeActivity exported without permission protection

HIGH, CVSS v4.0 AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N, 7.3 — local attack vector, exploitable by any other app already installed on the same device

```
<activity
    android:name="at.is24.mobile.finance.calculator.MortgageCalculatorComposeActivity"
    android:exported="true"
    android:windowSoftInputMode="adjustResize"/>
No android:permission attribute set.
```

Impact: at.is24.mobile.finance.calculator.MortgageCalculatorComposeActivity, into which users enter net income, available equity, and credit need, is declared android:exported=”true ” with no android:permission attribute. Any other application installed on the same device can start this activity directly, pre-fill it with attacker-chosen Intent extras, or trigger it in a way designed to mislead the user about which app is requesting the financial data being entered. Scout24's 6 July replies did not dispute the exported=”true” declaration or the absence of a permission attribute.

H3: Topics API, AD_ID, and attribution permissions layered on real-estate search behaviour constituting financial-intent data

---

MEDIUM, CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:R/VC:N/VI:N/VA:N/SC:L/SI:N/SA:N, 4.6 — downgraded from the original R1 finding's provisional HIGH label pending a formal Art. 35 DPIA determination by Scout24, consistent with RFI-IRFOS's practice of preferring a conservative CVSS-aligned severity over an unsupported escalation

Impact: ACCESS_ADSERVICES_TOPICS, ACCESS_ADSERVICES_AD_ID, ACCESS_ADSERVICES_ATTRIBUTION, and com.google.android.gms.permission.AD_ID are all declared. Real-estate search behaviour on this app, district, price range, property size, ownership type, combined with the mortgage calculator and solvency check elsewhere in the same app, constitutes financial-intent data from which a user's financial standing can be inferred. Building cross-app advertising interest profiles from this behaviour via the Topics API raises a possible Art. 9(1) touchpoint (financial situation as an inferred special category) and triggers an Art. 35 DPIA obligation for the combination. This finding was labeled HIGH in RFI-IRFOS's original R1 letter; it is presented here at MEDIUM, the level its CVSS v4.0 vector actually supports, since a conservative assessment is preferred over an escalation that Scout24's own replies did not have the opportunity to specifically address.

H4: Usercentrics CMP present (857 classes) but AppLovin, Google Mobile Ads, and Firebase all initialize pre-consent

---

MEDIUM, CVSS v4.0 AV:N/AC:H/AT:N/PR:N/UI:R/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N, 4.0 — documents awareness of the consent requirement coexisting with a configuration gap, not a missing control

Impact: Usercentrics (857 smali classes, full TCF 2.2 integration) is present and demonstrates that Scout24 is aware of and has implemented consent-management tooling. AppLovin (initOrder=101), Google Mobile Ads (initOrder=100), and Firebase (initOrder=100) all initialize via the ContentProvider mechanism before the Usercentrics consent dialog can be shown to the user. Having a functioning CMP and not gating the advertising and analytics SDKs behind it documents awareness without compliance, which is the more difficult posture to explain to a supervisory authority than having no CMP at all.

Impact Analysis

The two most severe findings, C1's hardcoded multi-service API keys and H1's pre-consent advertising SDK on a platform collecting net household income, are not disputed as facts anywhere in this correspondence; what is disputed is only whether they rise to the severity RFI-IRFOS assigned them. Scout24's Security Engineering team engaged quickly, within six days, and substantively, twice in one morning, which distinguishes this case from a silent one. But neither reply contested a single named manifest entry, resource value, or initOrder number, and neither answered any of the three specific yes/no questions about DPIA status, internal awareness, or remediation timing. After that exchange, six further follow-ups over 68 days drew nothing at all, through and past the stated embargo date.

The Complete Chain: Nine Messages, 109 Days, Two Early Replies That Disputed Severity Not Fact, Then Silence

Step 1 – Disclosure sent: RFI-IRFOS sends the full findings on 30 June 2026 to datenschutz@immobilienscout24.de (bounces immediately) and security@immobilienscout24.de, with Scout24's press office, the Austrian Datenschutzbehoerde, and the EDPS in CC and the German BfDI in BCC, stating an embargo of 28 September 2026.

Step 2 – Two replies in one morning: On 6 July 2026, security@scout24.com (Lani Lambert) replies twice within roughly 90 minutes. The first assesses the findings as medium-severity at most, frames them as requiring runtime validation, and redirects to Scout24's bug-bounty program. RFI-IRFOS responds the same morning, naming each finding as a deterministic manifest-level fact. The second reply acknowledges the underlying entries are observable by static analysis but maintains the medium-at-most assessment and repeats the bug-bounty redirect. Neither reply disputes a named fact or answers any of the three questions.

Step 3 – RFI-IRFOS's final word on the exchange: Later the same day, RFI-IRFOS sends a closing message restating that the three core findings require no runtime validation, being read directly from the shipped, unmodified APK.

Step 4 – Extended silence: Follow-ups on 23 July, 12 August, 14 August, 24 August, 3 September, and 12 September 2026 restate the findings and the three questions. None draws any reply.

Step 5 – Embargo passes unanswered: 28 September 2026, the stated embargo date, passes with the three questions still unanswered.

Step 6 – Publication: This report publishes 19 days after the embargo, 109 days after the original disclosure, with the full record intact: nine messages sent, two early replies that engaged quickly but disputed severity rather than fact, and 68 days of complete silence from the last reply through and past the embargo date.

Data Protection – Article by Article

Art. 32(1)(b) GDPR – Security of processing: C1's two hardcoded, unrestricted Google API keys spanning three cloud services fall short of the technical measures this provision requires.

Art. 7, Art. 5(1)(b), Art. 6(1) GDPR – Conditions for consent, purpose limitation, lawfulness of processing: H1's pre-consent initialization of AppLovin ahead of Firebase and the Usercentrics consent dialog, on a platform collecting net household income, raises all three provisions simultaneously.

Art. 32(1)(b), Art. 25 GDPR – Security of processing, data protection by design: H2's exported, permission-less mortgage-calculator activity is reachable by any other app on the same device.

Art. 5(1)(b), Art. 6(1), Art. 35 GDPR – Purpose limitation, lawfulness, and DPIA obligation: H3's combination of real-estate search behaviour, income data, and advertising-identifier profiling is the kind of combination Art. 35 exists to require a documented assessment of.

Art. 7, Recital 32 GDPR – Conditions for consent: H4's documented awareness (Usercentrics present) without compliance (ad SDKs not gated behind it) is the configuration Recital 32 and Art. 7 together are meant to prevent.

Regulatory & Legal Landscape

ImmoScout24 Austria is operated by Scout24 SE, headquartered in Berlin, placing it under the German BfDI and the relevant Bavarian supervisory authority as lead authorities for Scout24's own data processing, while at.is24.android is directed at users in Austria, giving the Austrian Datenschutzbehoerde an independent interest as the authority for users in its jurisdiction. Both the Datenschutzbehoerde and the EDPS were copied on the original disclosure and on follow-ups through 14 August 2026; the German BfDI was BCC'd on the original disclosure per RFI-IRFOS's standing practice.

Fine exposure under GDPR: Art. 83(4) applies to the Art. 32 issues in C1 and H2, up to EUR 10,000,000 or 2% of total worldwide annual turnover. Art. 83(5) applies to the Art. 5, Art. 6, Art. 7, and Art. 35 issues in H1, H3, and H4, up to EUR 20,000,000 or 4% of total worldwide annual turnover. Two prompt replies that dispute severity methodology while leaving the underlying facts, and three specific questions, unaddressed is itself a fact a supervisory authority may find relevant when assessing how this disclosure was handled internally.

Indicators of Compromise

The following findings were extracted from the production APK via static analysis only. No Scout24 servers, accounts, or infrastructure were probed. The hardcoded keys and database URL referenced in C1 are withheld from this public report; full values were disclosed privately to Scout24 in the original R1 letter.

```
C1 -- Two hardcoded Google API keys + Firebase Realtime Database URL,
  res/values/strings.xml, redacted in this public report

H1 -- AppLovin MAX (1,535 classes) initOrder=101, highest in app,
  ahead of Firebase/MobileAds/Usercentrics consent dialog

H2 -- MortgageCalculatorComposeActivity exported=true, no permission attribute

H3-H4 -- Topics API/AD_ID/Attribution permissions on financial-intent search
  behaviour; Usercentrics CMP present but not gating ad/analytics SDK init
```

Disclosure Timeline & Outcome

2026-06-30 Initial disclosure sent to datenschutz@immobilienscout24.de (bounces) and security@immobilienscout24.de, CC Scout24 press office, Austrian Datenschutzbehoerde, EDPS, BCC German BfDI. Embargo stated as 2026-09-28.

2026-07-06 07:58 Scout24 SE (security@scout24.com, Lani Lambert) replies: medium-severity at most, static-only, redirects to bug-bounty program.

2026-07-06 08:26 RFI-IRFOS responds, naming each finding as a manifest-level fact.

2026-07-06 09:46 Scout24 SE replies again: does not dispute the facts are observable, maintains medium-at-most assessment, repeats bug-bounty redirect. Neither reply answers the three questions.

2026-07-06 12:30 RFI-IRFOS sends a closing message on the exchange.

2026-07-23 Follow-up sent. No reply.

2026-08-12 Follow-up sent, address switched to is24-datenschutz@scout24.com alongside security@scout24.com. No reply.

2026-08-14 Follow-up sent. No reply.

2026-08-24 Follow-up sent. No reply.

2026-09-03 Follow-up sent. No reply.

2026-09-12 Follow-up sent, 74 days since original disclosure. No reply.

2026-09-28 Embargo date reached and passed with the three questions still unanswered.

2026-10-17 This report published, 19 days after the embargo date. Correspondence record: nine RFI-IRFOS messages, two early replies disputing severity but not fact, zero of three questions ever answered.

Residual Risk & Recommendations

C1 – Immediate: restrict both hardcoded Google API keys to the production signing certificate and their intended API scopes, confirm the Firebase Realtime Database security rules are deny-by-default, and rotate both keys after disclosure.

H1 – Gate AppLovin, Google Mobile Ads, and Firebase initialization behind the existing Usercentrics consent dialog rather than ahead of it; the CMP integration already exists and only needs to run first.

H2 – Remove android:exported="true" from MortgageCalculatorComposeActivity or add an android:permission attribute scoped to Scout24's own app family.

H3 – Complete and document an Art. 35 DPIA for the combination of real-estate search behaviour, income data, and advertising-identifier profiling.

H4 – Extend the existing Usercentrics gating to cover the advertising and analytics SDKs it does not currently gate.

Procedural: two replies that engage quickly but dispute severity methodology without disputing a single named fact, and without answering the specific questions asked, do not resolve the findings that required an answer. RFI-IRFOS remains open to a substantive reply to the three questions at any time; this report will be updated to reflect one if it arrives.

RFI-IRFOS security@rfi-irfos.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria All findings derive from static analysis of the published application using publicly available tooling. No Scout24 servers, accounts, or infrastructure were probed. The hardcoded credentials and database URL referenced in finding C1 are withheld from this public report; full values were disclosed privately to Scout24 in the original R1 letter and remain available to Scout24 or to a supervisory authority on request. Technical evidence is archived under chain of custody. Research conducted under ISO/IEC 29147, the freedom of scientific research (Art. 17 StGG) and GDPR Art. 89. REF IS24-AT-2026.